

INCIDENT ANALYSIS: DLL HIJACKING AND EXPLOITATION OF CVE-2021-36934

I. TỔNG QUAN SỰ CỐ

Hệ thống giám sát phát hiện 7z2301-x64 có một số hoạt động bất thường trên máy Windows, bao gồm việc một ứng dụng hợp lệ tải một thư viện DLL từ vị trí bất thường và xuất hiện các tiến trình không phù hợp với hành vi thông thường của ứng dụng.

Quá trình phân tích ban đầu cho thấy hệ thống có khả năng đã bị lợi dụng thông qua kỹ thuật DLL Hijacking, trong đó một DLL do kẻ tấn công triển khai được đặt tại vị trí mà ứng dụng mục tiêu có thể tìm kiếm và tải trước thư viện hợp lệ. Sau khi DLL được nạp thành công, mã do kẻ tấn công kiểm soát được thực thi.

Trong quá trình điều tra, các dấu vết tiếp theo cho thấy hoạt động liên quan đến việc truy cập các Registry Hive quan trọng của Windows, đặc biệt là SAM, SYSTEM và SECURITY. Điều này dẫn đến nghi vấn kẻ tấn công đã cố gắng khai thác CVE-2021-36934, còn được biết đến với tên HiveNightmare/SeriousSAM, nhằm truy cập trái phép vào các bản sao Registry Hive trên hệ thống bị ảnh hưởng.

Sysmon đã được cài đặt trên máy nạn nhân trước đó. Sysmon được cấu hình thông qua file XML configuration. Các hoạt động được Sysmon theo dõi bao gồm:

- Process Creation.
- Network Connection.
- Image/DLL Loading.
- File Creation.
- Registry Activity.
- Process Access.
- CreateRemoteThread.

II. QUY TRÌNH THU THẬP THÔNG TIN

Bước 1: Cô lập thiết bị

Mục tiêu: Ngăn chặn kẻ tấn công tiếp tục duy trì quyền truy cập vào hệ thống, thực hiện các hoạt động leo thang đặc quyền, thu thập Registry Hive hoặc xóa các dấu vết liên quan đến cuộc tấn công.

Việc cô lập thiết bị cũng nhằm hạn chế khả năng:

- Kẻ tấn công tiếp tục thực thi mã thông qua DLL đã bị cài cắm.
- Tạo thêm tiến trình hoặc cơ chế duy trì quyền truy cập.
- Truy cập hoặc sao chép các Registry Hive quan trọng.
- Truyền dữ liệu ra khỏi hệ thống.
- Xóa file, Event Logs hoặc các artifact phục vụ cho quá trình điều tra.

Thực hiện: Ngắt kết nối mạng của máy Windows bị ảnh hưởng nhưng không tắt nguồn hệ thống.

Bước 2: Thu thập ảnh chụp bộ nhớ và ổ đĩa

Thu thập RAM: Tiến hành thu thập Memory Dump của hệ thống trước khi thực hiện bất kỳ hoạt động khắc phục nào.

Mục tiêu của việc phân tích RAM là xác định:

- Tiến trình nào đang thực thi tại thời điểm xảy ra sự cố.
- Ứng dụng hợp lệ nào đã tải DLL đáng ngờ.
- Đường dẫn của DLL được nạp.
- Process ID và Parent Process ID.
- Các tiến trình con được tạo sau khi DLL được thực thi.
- Các kết nối mạng đang hoạt động.
- Dấu vết của mã độc hoặc payload tồn tại trong bộ nhớ.

Thu thập ảnh đĩa: tiến hành tạo bản sao forensic image của ổ đĩa hệ thống.

Ảnh đĩa được sử dụng nhằm bảo toàn các artifact quan trọng phục vụ điều tra, bao gồm:

- File DLL đáng ngờ.
- File thực thi đã tải DLL.
- Windows Event Logs.
- Registry Hives.
- Prefetch.
- Amcache.
- Shimcache.
- \$MFT.

III. PHÂN TÍCH BAN ĐẦU VÀ XÁC ĐỊNH ĐIỂM XÂM NHẬP

Hệ thống giám sát phát hiện 7z2301-x64 có một số hoạt động bất thường trên máy đây là một phát hiện quan trọng giúp tập trung vào đầu vào hành vi cách tấn công của hacker.

Bước 1: Xác định phiên bản và hệ điều hành.

Registry cho thấy hệ thống đang sử dụng Windows 10 Enterprise LTSC 2019 Version 1809 với OS Build 17763.107.

Value Name	Value Type	Data	Value Slack
 c	 c	 c	 c
SystemRoot	RegSz	C:\Windows	00-00-00-00-00-00
BuildBranch	RegSz	rs5_release	00-00-00-00
BuildGUID	RegSz	ffffffff-ffff-ffff-ffffffffffff	00-00
BuildLab	RegSz	17763.rs5_release.180914-1434	
BuildLabEx	RegSz	17763.1.amd64fre.rs5_release.180914-1434	00-00
CompositionEditionID	RegSz	EnterpriseS	00-00-00-05
CurrentBuild	RegSz	17763	
CurrentBuildNumber	RegSz	17763	
CurrentMajorVersionNumber	RegDword	10	
CurrentMinorVersionNumber	RegDword	0	
CurrentType	RegSz	Multiprocessor Free	65-00-64-00-00-00-00-00-00-00...
CurrentVersion	RegSz	6.3	00-00-00-00
EditionID	RegSz	EnterpriseS	00-00-00-00
EditionSubManufacturer	RegSz		
EditionSubstring	RegSz		
EditionSubVersion	RegSz		
InstallationType	RegSz	Client	00-00-00-00-00-00
InstallDate	RegDword	1786309263	
ProductName	RegSz	Windows 10 Enterprise LTSC 2019	00-00-00-00
ReleaseId	RegSz	1809	00-00
SoftwareType	RegSz	System	00-00-00-00-00-00
UBR	RegDword	107	
PathName	RegSz	C:\Windows	00-00-00-00-00-00
ProductId	RegSz	00425-00000-00002-AA195	36-34-7E-7E
DigitalProductId	RegBinary	A4-00-00-00-03-00-00-00-30-30-34-32-35-2D-30-30-30-30-30-2D-30-...	
DigitalProductId4	RegBinary	F8-04-00-00-04-00-00-00-35-00-35-00-30-00-34-00-31-00-2D-00-30-...	30-2E-31-37

Hình 1: Xác định phiên bản và hệ điều hành

Thông tin Windows 10 Enterprise LTSC 2019 Version 1809 với OS Build 17763.107. đã gặp 1 CVE-2021-36934 cho phép copy các Hive quan trọng liên quan đến leo thang đặc quyền.

Lỗ hổng bảo mật CVE-2021-36934 đã được vá vào ngày 10 tháng 8 năm 2021. Xem phần Cập nhật ở cuối bài đăng này để biết thêm thông tin.

Vào thứ Hai, ngày 19 tháng 7 năm 2021, các nhà nghiên cứu bảo mật cộng đồng bắt đầu báo cáo rằng tệp Quản lý Tài khoản Bảo mật (SAM) trên hệ thống Windows 10 và 11 đã được bật quyền ĐỌC cho tất cả người dùng cục bộ. Tệp SAM được sử dụng để lưu trữ thông tin bảo mật nhạy cảm, chẳng hạn như mật khẩu người dùng và quản trị viên đã được mã hóa. Việc bật quyền ĐỌC có nghĩa là kẻ tấn công có được quyền truy cập vào hệ thống có thể sử dụng thông tin liên quan đến bảo mật này để leo thang đặc quyền hoặc truy cập dữ liệu khác trong môi trường mục tiêu.

Vào thứ Ba, ngày 20 tháng 7, Microsoft đã đưa ra một thông báo ngoài luồng về lỗ hổng này, hiện được theo dõi với mã số CVE-2021-36934. Tính đến ngày 22 tháng 7 năm 2021, lỗ hổng này đã được xác nhận ảnh hưởng đến Windows 10 phiên bản 1809 trở lên. Một bằng chứng công khai về khả năng khai thác đã được công bố, cho phép người dùng không có quyền quản trị truy xuất tất cả các nhánh registry. Nhà nghiên cứu Kevin Beaumont cũng đã phát hành một bản demo xác nhận rằng CVE-2021-36934 có thể được sử dụng để lấy các hàm băm cục bộ và chuyển chúng đến một máy tính từ xa, đạt được khả năng thực thi mã từ xa với quyền SYSTEM trên các mục tiêu tùy ý (ngoài việc leo thang đặc quyền). Cộng đồng bảo mật đã đặt tên cho lỗ hổng này là "HiveNightmare" và "SeriousSAM".

Hình 2: Thông tin Windows 10 Enterprise LTSC 2019 Version 1809

Bước 2: Dùng FTK Image để thu thập thông tin.

Sau khi thu thập dữ liệu từ thư mục 7z2301-x64, các file hiện có được đối chiếu với bộ cài đặt 7-Zip 23.01 x64 nguyên bản được tải từ nguồn chính thức. Kết quả cho thấy thư mục trên máy người dùng có một số thành phần không thuộc cấu trúc thông thường của bộ cài đặt.

Các phát hiện đáng chú ý bao gồm:

- Xuất hiện file g_7z.dll, không được tìm thấy trong thư mục cài đặt chuẩn được sử dụng để đối chiếu.
- File thực thi HiveNightmare.exe xuất hiện trong thư mục 7z2301-x64 nhưng không thuộc các thành phần hợp lệ của gói 7-Zip.
- Ba file Registry Hive gồm SAM, SECURITY và SYSTEM xuất hiện trong cùng thư mục với các file của 7-Zip.

Name	Size	Type	Date Accessed	Date Created	Date Modified
Lang	368 (1 KB)	Directory	8/11/2026 2:12:04 PM	8/10/2026 7:42:40 AM	8/10/2026 7:42:42 AM
\$I30	4,096 (4 KB)	NTFS Index All...	8/11/2026 5:10:49 PM	8/10/2026 7:42:39 AM	8/11/2026 1:03:45 PM
7-zip.chm	115,300 (113 KB)	Regular File	8/11/2026 12:55:30 PM	8/10/2026 7:42:39 AM	6/20/2023 7:00:00 AM
7-zip.dll	101,376 (99 KB)	Regular File	8/11/2026 12:55:31 PM	8/10/2026 7:42:39 AM	6/20/2023 8:00:00 AM
7-zip32.dll	66,560 (65 KB)	Regular File	8/11/2026 12:55:31 PM	8/10/2026 7:42:39 AM	6/20/2023 8:00:00 AM
7z.dll	12,800 (13 KB)	Regular File	8/11/2026 12:55:43 PM	8/10/2026 7:42:40 AM	8/9/2026 10:29:50 AM
7z.exe	557,056 (544 KB)	Regular File	8/11/2026 1:03:46 PM	8/10/2026 7:42:40 AM	6/20/2023 8:00:00 AM
7z.sfx	214,528 (210 KB)	Regular File	8/11/2026 12:55:31 PM	8/10/2026 7:42:40 AM	6/20/2023 8:00:00 AM
7zCon.sfx	193,024 (189 KB)	Regular File	8/11/2026 12:55:31 PM	8/10/2026 7:42:40 AM	6/20/2023 8:00:00 AM
7zFM.exe	952,832 (931 KB)	Regular File	8/11/2026 5:10:14 PM	8/10/2026 7:42:40 AM	6/20/2023 8:00:00 AM
7zG.exe	700,416 (684 KB)	Regular File	8/11/2026 12:55:43 PM	8/10/2026 7:42:40 AM	6/20/2023 8:00:00 AM
debug_log.txt	1,661 (2 KB)	Regular File	8/11/2026 12:55:30 PM	8/10/2026 7:42:40 AM	8/9/2026 10:23:57 AM
descript.ion	366 (1 KB)	Regular File	8/11/2026 12:55:30 PM	8/10/2026 7:42:40 AM	1/28/2018 9:00:00 AM
g_7z.dll	1,841,664 (1,79...	Regular File	8/11/2026 12:55:43 PM	8/10/2026 7:42:40 AM	6/20/2023 8:00:00 AM
History.txt	58,305 (57 KB)	Regular File	8/11/2026 12:55:30 PM	8/10/2026 7:42:40 AM	6/20/2023 7:00:00 AM
HiveNightmare.exe	227,328 (222 KB)	Regular File	8/11/2026 1:03:46 PM	8/11/2026 1:00:16 PM	8/11/2026 1:00:16 PM
License.txt	3,990 (4 KB)	Regular File	8/11/2026 12:55:31 PM	8/10/2026 7:42:40 AM	5/5/2023 1:00:00 PM
readme.txt	1,708 (2 KB)	Regular File	8/11/2026 12:55:31 PM	8/10/2026 7:42:40 AM	6/20/2023 9:00:00 AM
SAM-2026-08-11	65,536 (64 KB)	Regular File	8/11/2026 1:11:47 PM	8/11/2026 1:03:45 PM	8/11/2026 1:03:45 PM
SECURITY-2026-08-11	65,536 (64 KB)	Regular File	8/11/2026 1:03:46 PM	8/11/2026 1:03:45 PM	8/11/2026 1:03:45 PM
SYSTEM-2026-08-11	11,534,336 (11,...	Regular File	8/11/2026 1:11:53 PM	8/11/2026 1:03:45 PM	8/11/2026 1:03:45 PM
Uninstall.exe	14,848 (15 KB)	Regular File	8/11/2026 12:55:31 PM	8/10/2026 7:42:40 AM	6/20/2023 7:00:00 AM

Hình 3: Foder 7z2301-x64 trong máy user

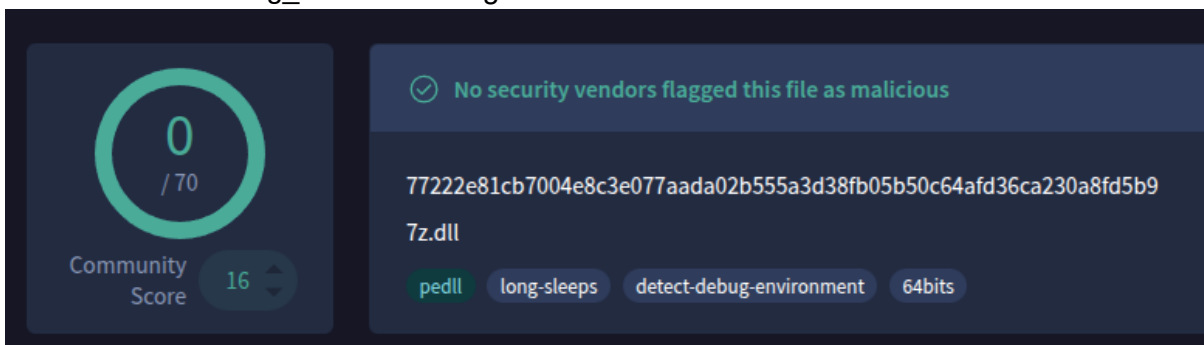
Kết hợp bước 1 và bước 2 trong điều tra thì có thể nhận định rằng hacker đã khai thác CVE-2021-36934 và Sự xuất hiện 7-Zip 23.01 x64 đến từ việc việc user đã tải từ trên mạng theo lịch sử website.

IV. PHÂN TÍCH CƠ CHẾ MALWARE

1. Phân tích thư mục 7-Zip 23.01 x64

Trước đó xuất hiện file g_7z.dll dùng FTK export file g_7z -> dùng certutil -hashfile để lấy hash -> Virustotal để đánh giá file.

=> Theo VirusTotal thì g_7z.dll mới đúng là 7z.dll



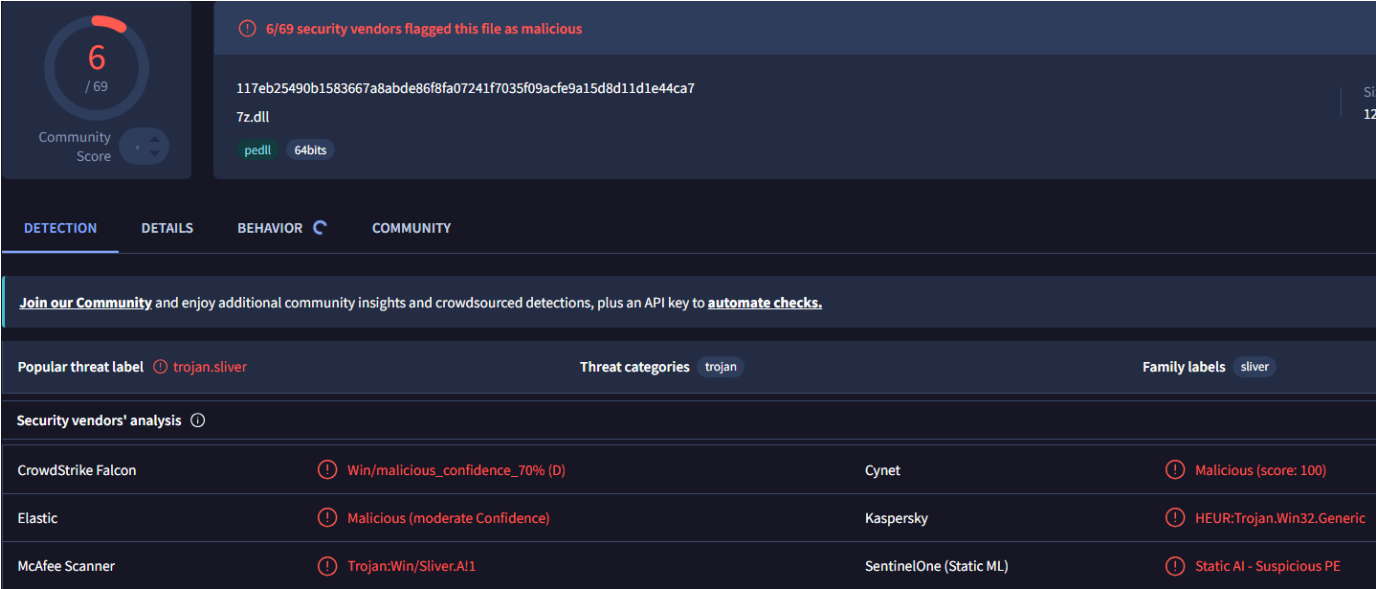
Hình 4: g_7z phân tích VirusTotal

Vậy file 7z.dll xuất hiện trong 7-Zip 23.01 x64 là file gì ? Dùng lại cách vừa rồi phân tích phân tích 7z.dll xuất hiện trong Foder.

Cynet đánh giá file ở mức Malicious với score 100, trong khi CrowdStrike Falcon và Elastic cũng phân loại file là có khả năng độc hại. Kaspersky nhận diện file dưới dạng heuristic HEUR:Trojan.Win32.Generic, cho thấy cấu trúc hoặc hành vi của file có các đặc điểm thường gặp ở mã độc Trojan.

Đặc biệt, McAfee Scanner nhận diện file với tên: Trojan:Win/Sliver.A!1 Kết quả này cho thấy file có các đặc điểm hoặc mẫu mã tương đồng với thành phần liên quan đến Sliver

Kết luận: 7z.dll xuất hiện trong thư mục mà 1 dll độc hại nhưng g_7z.dll được xem là 7z.dll gốc thực sự => khả năng 7z.dll xuất hiện trong thư mục chính là dấu hiệu của DLL Hijacking/side-loading. Dùng dll giả để gọi các hàm trong 7z.dll thật.

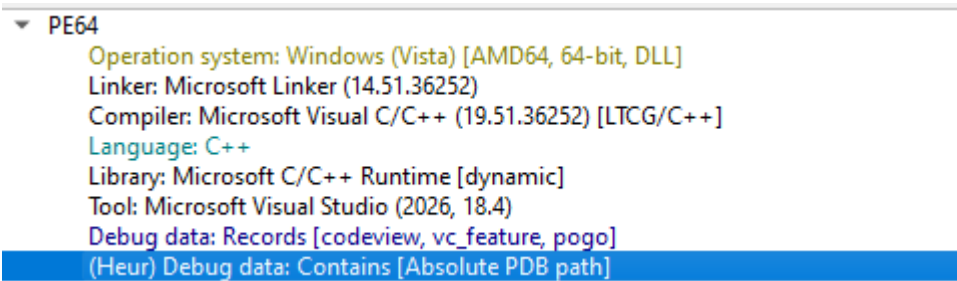


Hình 5: 7z.dll phân tích VirusTotal

1.2. Phân tích hành vi 7z.dll giả mạo

Kết quả từ Detect It Easy cho thấy g_7z.dll là một Windows DLL kiến trúc 64-bit, được viết bằng C++ và biên dịch bằng Microsoft Visual C++.

File cũng chứa CodeView Debug Information và Absolute PDB Path, cho thấy DLL vẫn lưu lại thông tin liên quan đến môi trường biên dịch.



Hình 6: 7z.dll trong DIE

Trong section .data chứa mã và dữ liệu của DLL
Sự xuất hiện của wininet cho thấy DLL có khả năng sử dụng Windows Internet API để thực hiện giao tiếp mạng.

imports (28)	flag (4)	type
VirtualAlloc	x	implicit
CreateThread	-	implicit
CloseHandle	-	implicit
DisableThreadLibraryCalls	-	implicit
GetModuleHandleExW	x	implicit
GetModuleFileNameA	-	implicit
LoadLibraryA	-	implicit
GetProcAddress	-	implicit
FreeLibrary	-	implicit
GetCurrentProcessId	x	implicit
GetCurrentThreadId	x	implicit

Hình 9: Imports 7z.dll trong PESTUDIO

Trong IDA DLL export các hàm giống 7z.dll hợp lệ, Đúng với tính chất của DLL HIJACKING

Name	Address	Ordinal
CreateDecoder	00000000180001080	1
CreateEncoder	00000000180001090	2
CreateObject	000000001800010A0	3
GetHandlerProperty	000000001800010B0	4
GetHandlerProperty2	000000001800010C0	5
GetHashers	000000001800010D0	6
GetIsArc	000000001800010E0	7
GetMethodProperty	000000001800010F0	8
GetModuleProp	00000000180001100	9
GetNumberOfFormats	00000000180001110	10
GetNumberOfMethods	00000000180001120	11
SetCaseSensitive	00000000180001130	12
SetCodecs	00000000180001140	13
SetLargePageMode	00000000180001150	14
DllEntryPoint	000000001800017A0	[main entry]

Hình 10: 7z.dll export trong IDA

IDA cho thấy hàm StartAddress gọi API: call: cs:VirtualAlloc, Hàm cấp phát vùng nhớ với kích thước 0x302 byte, sử dụng MEM_COMMIT | MEM_RESERVE và quyền PAGE_EXECUTE_READWRITE (RWX)

=> Việc cấp phát vùng nhớ có quyền đọc, ghi và thực thi cho thấy DLL chuẩn bị một vùng nhớ có khả năng chứa và chạy mã trực tiếp trong bộ nhớ.


```

; DWORD __stdcall StartAddress(LPVOID lpThreadParameter)
StartAddress proc near

dwCreationFlags= dword ptr -18h
lpThreadId= qword ptr -10h

push    rbx
sub     rsp, 30h
mov     edx, 302h          ; dwSize
xor     ecx, ecx           ; lpAddress
mov     r9d, 40h ; '@'     ; flProtect
mov     r8d, 3000h         ; flAllocationType
call    cs:VirtualAlloc
mov     rbx, rax
test    rax, rax
jnz     short loc_180001032

```

Hình 11: StartAddress gọi VirtualAlloc

Sau khi cấp phát vùng nhớ RWX, DLL sao chép 0x302 byte dữ liệu từ unk_180004080 vào vùng nhớ này thông qua memmove. Sau đó, địa chỉ vùng nhớ được truyền vào CreateThread làm lpStartAddress

=> Chuỗi VirtualAlloc → memmove → CreateThread cho thấy DLL nạp payload được nhúng sẵn vào bộ nhớ và thực thi trực tiếp thông qua một luồng mới.

```

.text:0000000180001032 loc_180001032:          ; CODE XREF: StartAddress+25↑j
.text:0000000180001032          mov     r8d, 302h          ; Size
.text:0000000180001038          lea     rdx, unk_180004080 ; Src
.text:000000018000103F          mov     rcx, rbx         ; void *
.text:0000000180001042          call   memmove
.text:0000000180001047          xor     eax, eax
.text:0000000180001049          xor     r9d, r9d         ; lpParameter
.text:000000018000104C          mov     [rsp+38h+lpThreadId], rax ; lpThreadId
.text:0000000180001051          mov     r8, rbx         ; lpStartAddress
.text:0000000180001054          xor     edx, edx         ; dwStackSize
.text:0000000180001056          mov     [rsp+38h+dwCreationFlags], eax ; dwCreationFlags
.text:000000018000105A          xor     ecx, ecx         ; lpThreadAttributes
.text:000000018000105C          call   cs:CreateThread
.text:0000000180001062          test    rax, rax
.text:0000000180001065          jz      short loc_180001070
.text:0000000180001067          mov     rcx, rax         ; hObject
.text:000000018000106A          call   cs:CloseHandle

```

Hình 12: Chuỗi VirtualAlloc → memmove → CreateThread

StartAddress không được gọi trực tiếp mà được thực thi trong một thread riêng. Từ đó, thread này tiếp tục nạp payload vào vùng nhớ RWX và tạo thêm một thread để thực thi payload.

```

mov     [rsp+168h+lpThreadId], 0 ; lpThreadId
lea     r8, StartAddress ; lpStartAddress
xor     r9d, r9d ; lpParameter
mov     [rsp+168h+dwCreationFlags], 0 ; dwCreationFlags
xor     edx, edx ; dwStackSize
mov     cs:byte_180004420, 1
xor     ecx, ecx ; lpThreadAttributes
call    cs:CreateThread
test    rax, rax
jz      short loc_1800013FC

```

Hình 13: Nạp payload vào vùng nhớ RWX và tạo thêm một thread để thực thi payload

Trước đó: `lea rdx, unk_180004080 ; Source call memmove` Sau đó vùng nhớ chứa dữ liệu này được truyền vào:

```
mov r8, rbx ; lpStartAddress
```

```
call CreateThread
```

Vì vậy, `unk_180004080` chính là địa chỉ bắt đầu của 0x302 byte payload được copy và thực thi, nên byte đầu tiên tại đây được xác định là điểm bắt đầu của shellcode. 0x302 byte -> 770 byte bắt đầu từ `0x180004080` đến `0x180004381` chính là shellcode được nhúng.

shellcode x64 đặc biệt là các stub khởi tạo kinh điển thường thấy trong Metasploit/Cobalt Strike (FC 48 83 E4 F0...)

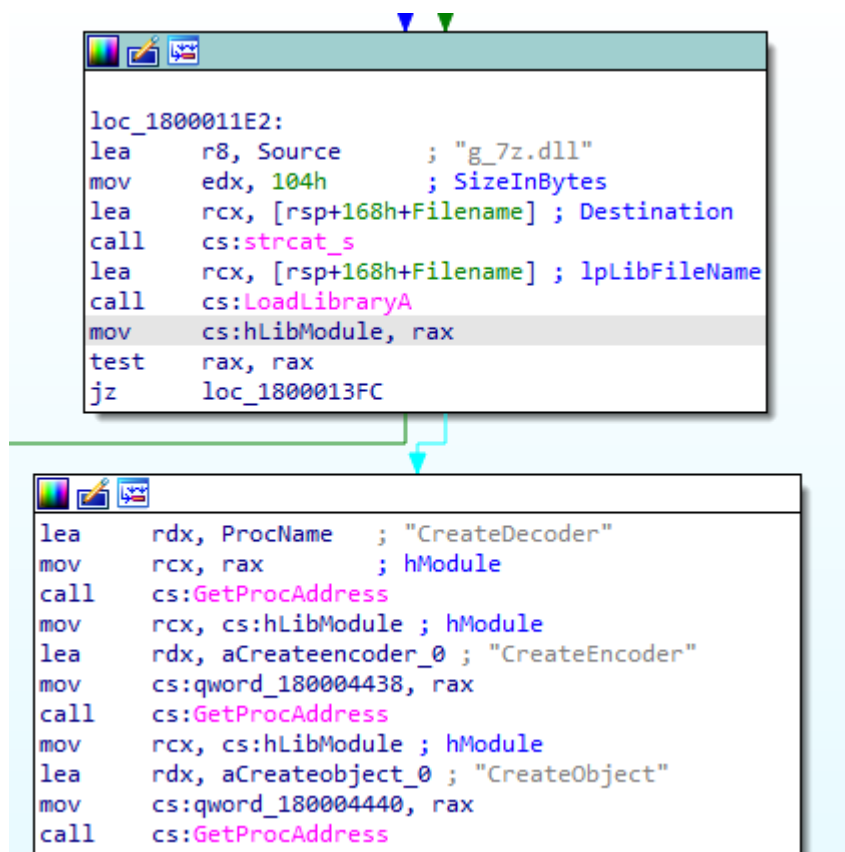
```

.data:0000000180004080 unk_180004080 db 0FCh ; DATA XREF: StartAddress+38fo
.data:0000000180004081 db 48h ; H
.data:0000000180004082 db 83h
.data:0000000180004083 db 0E4h
.data:0000000180004084 db 0F0h
.data:0000000180004085 db 0E8h
.data:0000000180004086 db 0CCh
.data:0000000180004087 db 0
.data:0000000180004088 db 0
.data:0000000180004089 db 0
.data:000000018000408A db 41h ; A
.data:000000018000408B db 51h ; Q
.data:000000018000408C db 41h ; A
.data:000000018000408D db 50h ; P
.data:000000018000408E db 52h ; R
.data:000000018000408F db 51h ; Q
.data:0000000180004090 db 56h ; V
.data:0000000180004091 db 48h ; H
.data:0000000180004092 db 31h ; l
.data:0000000180004093 db 0D2h
.data:0000000180004094 db 65h ; e
.data:0000000180004095 db 48h ; H
.data:0000000180004096 db 88h
.data:0000000180004097 db 52h ; R
.data:0000000180004098 db 60h ; `
.data:0000000180004099 db 48h ; H
.data:000000018000409A db 88h
.data:000000018000409B db 52h ; R
.data:000000018000409C db 18h
.data:000000018000409D db 48h ; H
.data:000000018000409E db 88h
.data:000000018000409F db 52h ; R
.data:00000001800040A0 db 20h
.data:00000001800040A1 db 41h ; A
.data:00000001800040A2 db 0B9h
.data:00000001800040A3 db 2
.data:00000001800040A4 db 0D1h
.data:00000001800040A5 db 88h
.data:00000001800040A6 db 44h ; D
.data:00000001800040A7 db 48h ; H

```

Hình 14: stub khởi tạo

7z.dll giả mạo vừa duy trì chức năng bình thường bằng cách chuyển tiếp các API sang g_7z.dll, vừa âm thầm tạo thread riêng để thực thi payload trong bộ nhớ. Đây là cơ chế cho phép DLL độc hại hoạt động mà không làm ứng dụng 7-Zip dễ bị lỗi hoặc dừng đột ngột.



```

call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aCreateencoder_0 ; "CreateEncoder"
mov cs:qword_180004438, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aCreateobject_0 ; "CreateObject"
mov cs:qword_180004440, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aGethandlerprop_1 ; "GetHandlerProperty"
mov cs:qword_180004448, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aGethandlerprop_2 ; "GetHandlerProperty2"
mov cs:qword_180004450, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aGethashers_0 ; "GetHashers"
mov cs:qword_180004458, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aGetisarc_0 ; "GetIsArc"
mov cs:qword_180004460, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aGetMethodprope_0 ; "GetMethodProperty"
mov cs:qword_180004468, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aGetmoduleprop_0 ; "GetModuleProp"
mov cs:qword_180004470, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aGetnumberoffor_0 ; "GetNumberOfFormats"
mov cs:qword_180004478, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule
lea rdx, aGetnumberofmet_0 ; "GetNumberOfMethods"
mov cs:qword_180004480, rax
call cs:GetProcAddress
mov rcx, cs:hLibModule ; hModule

```

Hình 15: Chuyển tiếp các API sang API gốc

Kết luận: 7z.dll trong thư mục 7-Zip được xác định là DLL giả mạo, có dấu hiệu rõ ràng của kỹ thuật DLL Hijacking/Side-Loading. DLL này giả lập các hàm export của 7z.dll hợp lệ để duy trì khả năng tương thích với 7-Zip, đồng thời chuyển tiếp chức năng sang g_7z.dll. Điểm đáng chú ý là DLL thực hiện chuỗi VirtualAlloc → memmove → CreateThread, trong đó cấp phát vùng nhớ RWX, sao chép khoảng 0x302 byte shellcode được nhúng tại 0x180004080, rồi tạo thread để thực thi trực tiếp trong bộ nhớ. Các byte đầu shellcode cũng mang đặc trưng của các stub x64 thường gặp trong framework/payload tấn công.

1.3. Phân tích hivenightmare.exe

HiveNightmare là tên thường dùng cho CVE-2021-36934 nó là một POC, một lỗ hổng phân quyền trên Windows cho phép người dùng không có quyền Administrator đọc trái phép các Registry Hive nhạy cảm

Mục tiêu chính là lấy các file:

C:\Windows\System32\config\SAM
C:\Windows\System32\config\SYSTEM
C:\Windows\System32\config\SECURITY

Người dùng thường có thể đọc các bản sao của những hive này từ Volume Shadow Copy, do ACL bị cấu hình sai.

VBA32	Exploit.HiveNightmare	VIPRE	Generic.Exploit.CVE-2021-36934.Marte.A...
ViRobot	Trojan.Win32.S.Exploit.227328	Webroot	W32.Trojan.Gen
WithSecure	Exploit:W32/HiveNightmare.A	Xcitium	Malware@#2xawxw8fipxte
Yandex	Exploit.CVE-2021-36934!LCo2X9MVUtM	ZoneAlarm by Check Point	Exp/2136934-A

Hình 16: Phân tích HiveNightmare

V. PHÂN TÍCH DUMP MEMORY

1. Tiến trình chạy trong RAM.

Có rất nhiều tiến trình được lạ được phát hiện, đặc biệt là Notepad.exe như đã biết trước đó 7z chính là nguồn gốc malware.

7zFM có PPID là 3416 là explorer.exe → 7zFM.exe, nhưng PPID của 2 tiến trình notepad đã không còn dấu vết => 2 tiến trình này không phải do người dùng mở, và không xuất hiện trong cmdline hay tiến trình ẩn nào.

1392	3416	7zFM.exe	0xa408f3447540	1	-	1	False	2026-08-11 12:53:33.000000	UTC	N/A	Disabled
4100	7156	notepad.exe	0xa408f4abe500	2	-	1	False	2026-08-11 12:55:30.000000	UTC	N/A	Disabled
2160	5560	notepad.exe	0xa408f4fd00c0	6	-	1	False	2026-08-11 12:55:41.000000	UTC	N/A	Disabled

Hình 17: Tiến trình nghi ngờ

Bây giờ liệt kê tất cả các handle đang được mở bởi PID của notepad là 4100 và 2160.

PID 2160 có handle trực tiếp tới: C:\Users\sam\Desktop\7z2301-x64\SAM-2026-08-11 và: C:\Users\sam\Desktop\7z2301-x64\SYSTEM-2026-08-11 Handle chứng minh process có tham chiếu mở tới các file

```
C:\Users\forensic\Desktop\volatility3-develop>python vol.py -f C:\Users\forensic\Desktop\DESKTOP-BMNA5D9-20260811-171459.dmp windows.handles --pid 2160 | findstr /I "File"
2160 notepad.exe 0xa408f4b98a20 0x40 File 0x100020 \Device\HarddiskVolume3\Users\sam\Desktop\7z2301-x64
2160 notepad.exe 0xa408f4d1ad40 0x6c File 0x100020 \Device\HarddiskVolume3\Windows\WinSxS\amd64_microsoft.windows.common-controls_6595b64144ccf1df_6.0
2160 notepad.exe 0xc609ab2b05b0 0x9c Key 0x9 MACHINE\SOFTWARE\MICROSOFT\WINDOWS NT\CURRENTVERSION\IMAGE FILE EXECUTION OPTIONS
2160 notepad.exe 0xa408f4d1aed0 0xb4 File 0x120089 \Device\HarddiskVolume3\Windows\System32\en-US\notepad.exe.mui
2160 notepad.exe 0xa408f46ea250 0xc8 File 0x100001 \Device\CNG
2160 notepad.exe 0xa408f46ea570 0x150 File 0x120089 \Device\DeviceApi\CMApi
2160 notepad.exe 0xa408f4d11ed0 0x1ec File 0x100003 \Device\KsecDD
2160 notepad.exe 0xa408f46ead40 0x290 File 0x120089 \Device\HarddiskVolume3\Windows\Fonts\StaticCache.dat
2160 notepad.exe 0xa408f4fcb3e0 0x344 File 0x120089 \Device\HarddiskVolume3\Windows\Registration\R0000000000006.clb
2160 notepad.exe 0xa408f4d11890 0x364 File 0x100020 \Device\HarddiskVolume3\Windows\WinSxS\amd64_microsoft.windows.common-controls_6595b64144ccf1df_6.0
2160 notepad.exe 0xa408f47930c0 0x408 File 0x100080 \Device\Nsi
2160 notepad.exe 0xa408f489ded0 0x490 File 0x120089 \Device\HarddiskVolume3\Windows\System32\en-US\winlnsres.dll.mui
2160 notepad.exe 0xa408f33523e0 0x4c8 File 0x16019f \Device\Afd\Endpoint
2160 notepad.exe 0xa408f4793d40 0x4cc File 0x120089 \Device\HarddiskVolume3\Windows\System32\en-US\mswsock.dll.mui
2160 notepad.exe 0xa408f4d06890 0x548 File 0x120089 \Device\NamedPipe\
2160 notepad.exe 0xa408f46e23e0 0x564 File 0x120189 \Device\NamedPipe
2160 notepad.exe 0xa408f4fc9a20 0x658 File 0x120089 \Device\HarddiskVolume3\Users\sam\Desktop\7z2301-x64\SAM-2026-08-11
2160 notepad.exe 0xa408f48c8d40 0x75c File 0x120196 \Device\NamedPipe
2160 notepad.exe 0xa408f4829a20 0x784 File 0x120089 \Device\HarddiskVolume3\Users\sam\Desktop\7z2301-x64\SYSTEM-2026-08-11
```

```
C:\Users\forensic\Desktop\volatility3-develop>python vol.py -f C:\Users\forensic\Desktop\DESKTOP-BMNA5D9-20260811-171459.dmp windows.handles --pid 4100 | findstr /I "File"
4100 notepad.exe 0xa408f47a7d40 0x40 File 0x100020 \Device\HarddiskVolume3\Users\sam\Desktop\7z2301-x64
4100 notepad.exe 0xa408f41cbb0 0x6c File 0x100020 \Device\HarddiskVolume3\Windows\WinSxS\amd64_microsoft.windows.common-controls_6595b64144ccf1df_6.0
4100 notepad.exe 0xc609a714ccb0 0xa4 Key 0x9 MACHINE\SOFTWARE\MICROSOFT\WINDOWS NT\CURRENTVERSION\IMAGE FILE EXECUTION OPTIONS
4100 notepad.exe 0xa408f4b9e0c0 0xbc File 0x120089 \Device\HarddiskVolume3\Windows\System32\en-US\notepad.exe.mui
4100 notepad.exe 0xa408f4b9e250 0xd0 File 0x100001 \Device\CNG
4100 notepad.exe 0xa408f47a7570 0x158 File 0x120089 \Device\DeviceApi\CMApi
4100 notepad.exe 0xa408f4918250 0x1f4 File 0x100003 \Device\KsecDD
4100 notepad.exe 0xa408f47a7ed0 0x298 File 0x120089 \Device\HarddiskVolume3\Windows\Fonts\StaticCache.dat
4100 notepad.exe 0xa408f3edfd40 0x338 File 0x120089 \Device\HarddiskVolume3\Windows\Registration\R0000000000006.clb
4100 notepad.exe 0xa408f3edf0c0 0x358 File 0x100020 \Device\HarddiskVolume3\Windows\WinSxS\amd64_microsoft.windows.common-controls_6595b64144ccf1df_6.0
```

Hình 18: liệt kê tất cả các handle đang được mở bởi PID của notepad là 4100 và 2160.

Dùng malfind Để xác định vùng memory đó có dấu hiệu process injection.

Phát hiện cả hai tiến trình notepad.exe PID 4100 và PID 2160 chứa các vùng nhớ Private PAGE_EXECUTE_READWRITE với shellcode x64 có cấu trúc tương tự, cho thấy dấu hiệu mạnh của việc thực thi mã đáng ngờ/process injection trong cả hai tiến trình hợp lệ.

```
2160 notepad.exe 0x1cae2880000 0x1cae2880fff VadS PAGE_EXECUTE_READWRITE 1 1 Disabled N/A
fc 55 57 56 48 89 e7 e9 01 01 00 00 5e 48 83 ec .UMVH.....^H..
78 e8 c8 00 00 00 41 51 41 50 52 51 56 48 31 d2 x....AQAPROVH1.
65 48 8b 52 60 48 8b 52 18 48 8b 52 20 48 8b 72 eH.R'H.R.H.R H.r
50 48 0f b7 4a 4a 4d 31 c9 48 31 c0 ac 3c 61 7c PH..JJM1.H1..<a|
52 18 48 8b 52 20 48 8b 72 50 48 0f b7 4a 4a 4d 31 c9 48 31 c0 ac 3c 61 7c
2160 notepad.exe 0x1cae4140000 0x1cae417efff VadS PAGE_EXECUTE_READWRITE 63 1 Disabled N/A
fc 48 89 ce 48 81 ec 00 20 00 00 48 83 e4 f0 e8 .H..H... ..H....
cc 00 00 00 41 51 41 50 52 51 56 48 31 d2 65 48 ....AQAPROVH1.eH
8b 52 60 48 8b 52 18 48 8b 52 20 41 b9 c1 65 12 .R'H.R.H.R A..e.
d6 48 8b 72 50 48 0f b7 4a 48 48 31 c0 ac 3c 61 .H.rPH..JH11..<a
48 8b 52 20 41 b9 c1 65 12 d6 48 8b 72 50 48 0f b7 4a 48 48 31 c0 ac 3c 61
```

```
4100 notepad.exe 0x29ac36a0000 0x29ac36defff VadS PAGE_EXECUTE_READWRITE 63 1 Disabled N/A
fc 48 89 ce 48 81 ec 00 20 00 00 48 83 e4 f0 e8 .H..H... ..H....
cc 00 00 00 41 51 41 50 52 48 31 d2 51 56 65 48 ....AQAPRH1.QVeH
8b 52 60 48 8b 52 18 48 8b 52 20 48 8b 72 50 48 .R'H.R.H.R H.rPH
0f b7 4a 48 41 b9 89 20 88 95 48 31 c0 ac 3c 61 .JHA... ..H1..<a
48 8b 52 20 48 8b 72 50 48 0f b7 4a 48 41 b9 89 20 88 95 48 31 c0 ac 3c 61
4100 notepad.exe 0x29ac36e0000 0x29ac36e0fff VadS PAGE_EXECUTE_READWRITE 1 1 Disabled N/A
fc 55 57 56 48 89 e7 e9 01 01 00 00 5e 48 83 ec .UMVH.....^H..
78 e8 c8 00 00 00 41 51 41 50 52 51 56 48 31 d2 x....AQAPROVH1.
65 48 8b 52 60 48 8b 52 18 48 8b 52 20 48 8b 72 eH.R'H.R.H.R H.r
50 48 0f b7 4a 4a 4d 31 c9 48 31 c0 ac 3c 61 7c PH..JJM1.H1..<a|
52 18 48 8b 52 20 48 8b 72 50 48 0f b7 4a 4a 4d 31 c9 48 31 c0 ac 3c 61 7c
```

Hình 19: Dấu hiệu process injection

PID 4100 và PID 2160 có cấu trúc memory gần như giống nhau, chỉ khác địa chỉ cấp phát. Cả 4 vùng đều có: VadS PAGE_EXECUTE_READWRITE PrivateMemory = 1 File backing = N/A

```
C:\Users\forensic\Desktop\volatility3-develop>python vol.py -f C:\Users\forensic\Desktop\DESKTOP-BMNA5D9-20260811-171459.dmp windows.vadinfo --pid 4100 | findstr /I "29ac36a 29ac36e"
4100 notepad.exe 0xfffffa408f4f082e0 0x29ac36a0000 0x29ac36defff VadS PAGE_EXECUTE_READWRITE 63 1 0xfffffa408f3ffa050 N/A Disabled
4100 notepad.exe 0xfffffa408f4f08ba0 0x29ac36e0000 0x29ac36e0fff VadS PAGE_EXECUTE_READWRITE 1 1 0xfffffa408f3995b90 N/A Disabled

C:\Users\forensic\Desktop\volatility3-develop>python vol.py -f C:\Users\forensic\Desktop\DESKTOP-BMNA5D9-20260811-171459.dmp windows.vadinfo --pid 2160 | findstr /I "1cae288 1cae414"
2160 notepad.exe 0xfffffa408f40e0330 0x1cae2880000 0x1cae2880fff VadS PAGE_EXECUTE_READWRITE 1 1 0xfffffa408f40e0240 N/A Disabled
2160 notepad.exe 0xfffffa408f40e0600 0x1cae4140000 0x1cae417efff VadS PAGE_EXECUTE_READWRITE 63 1 0xfffffa408f3e0c910 N/A Disabled
```

Hình 20: 4 vùng nhớ PID 4100 và PID 2160

1.2. Dump Memory Notepad.

Sau khi so sánh thì vùng nhớ PID 4100 và PID 2160 gần như giống nhau cho. cho nên ta chỉ phân tích 1 cái.

2160_A_lon.dmp	8/14/2026 8:36 PM	DMP File	252 KB
2160_B_nho.dmp	8/14/2026 8:36 PM	DMP File	4 KB
4100_A_lon.dmp	8/14/2026 8:37 PM	DMP File	252 KB
4100_B_nho.dmp	8/14/2026 8:37 PM	DMP File	4 KB

Hình 21: Dump bốn vùng nhớ PID 4100 và PID 2160

Tạo 1 đoạn code Python dùng để đọc một file nhị phân.

```
main.py
1 filename = "4100_A_lon.dmp"
2
3 with open(filename, "rb") as f:
4     data = f.read()
5
6 print("File size:", len(data))
7
8 print("\n=== HEX from offset 0xE0 to 0x200 ===")
9
10 for i in range(0xE0, 0x200, 16):
11     chunk = data[i:i+16]
12
13     hexdata = " ".join(f"{b:02x}" for b in chunk)
14
15     ascii_data = "".join(
16         chr(b) if 32 <= b <= 126 else "."
17         for b in chunk
18     )
19
20 print(f"{i:08x} {hexdata:<47} {ascii_data}")
```

Hình 22: Code đọc nhị phân.

Vùng 4100_A_lon.dmp không chỉ chứa shellcode ở đầu, mà ngay sau stub shellcode có một PE file được nhúng trong memory: 00000100 4d 5a là MZ

This program cannot be run in DOS mode. Đây là DOS stub của một file PE.

```
=== HEX from offset 0xE0 to 0x200 ===
000000e0  5d 48 8b 0e 41 ba d6 0f a7 fc ff d5 ff 56 08 60  ]H..A.....V.
000000f0  03 00 00 00 00 00 00 ff 00 6a c3 9a 02 00 00 4d  .....j.....M
00000100  5a 41 52 55 48 89 e5 48 83 ec 20 48 83 e4 f0 e8  ZARUH..H.. H...
00000110  00 00 00 00 5b 48 81 c3 ab 67 00 00 ff d3 48 81  ....[H...g....H.
00000120  c3 40 7e 03 00 48 89 3b 49 89 d8 6a 04 5a ff d0  .@~...H.;I..j.Z..
00000130  00 00 00 00 00 00 00 00 00 00 00 08 01 00 00 0e  .....
00000140  1f ba 0e 00 b4 09 cd 21 b8 01 4c cd 21 54 68 69  .....!..L.!Thi
00000150  73 20 70 72 6f 67 72 61 6d 20 63 61 6e 6e 6f 74  s program cannot
00000160  20 62 65 20 72 75 6e 20 69 6e 20 44 4f 53 20 6d  be run in DOS m
00000170  6f 64 65 2e 0d 0d 0a 24 00 00 00 00 00 00 00 5c  ode....$......\
00000180  d6 9f 87 18 b7 f1 d4 18 b7 f1 d4 18 b7 f1 d4 ac  .....
00000190  2b 00 d4 1f b7 f1 d4 ac 2b 02 d4 66 b7 f1 d4 ac  +.....+..f....
000001a0  2b 03 d4 15 b7 f1 d4 4a c2 f4 d5 05 b7 f1 d4 4a  +.....J.....J
000001b0  c2 f5 d5 08 b7 f1 d4 4a c2 f2 d5 11 b7 f1 d4 11  .....J.....
000001c0  cf 76 d4 19 b7 f1 d4 11 cf 62 d4 17 b7 f1 d4 18  .v.....b.....
000001d0  b7 f0 d4 d8 b7 f1 d4 d2 c2 f5 d5 07 b7 f1 d4 d2  .....
000001e0  c2 f2 d5 19 b7 f1 d4 d2 c2 f1 d5 19 b7 f1 d4 d2  .....
000001f0  c2 f3 d5 19 b7 f1 d4 52 69 63 68 18 b7 f1 d4 00  .....Rich.....
```

Hình 23: Phân tích 4100_A_lon.dmp

Script để tìm tất cả vị trí MZ Có 8 vị trí chứa chuỗi byte 4D 5A (MZ): 0xff 0x59cb 0x5c1a 0x6d57 0x18d45 0x19767 0x1ff3f 0x2a330 Nhưng không phải MZ nào cũng là PE hợp lệ.

```
main.py
1  filename = "4100_A _lon.dmp"
2
3  with open(filename, "rb") as f:
4      data = f.read()
5
6  offset = 0
7
8  while True:
9      offset = data.find(b"MZ", offset)
10
11     if offset == -1:
12         break
13
14     print(f"MZ found at: {hex(offset)}")
15
16     offset += 1
```

Hình 24: Code tìm tất cả vị trí MZ trong PID 4100


```
E:\dmp>python main.py
MZ found at: 0xff
MZ found at: 0x59cb
MZ found at: 0x5c1a
MZ found at: 0x6d57
MZ found at: 0x18d45
MZ found at: 0x19767
MZ found at: 0x1ff3f
MZ found at: 0x2a330
```

Kết quả:

kiểm tra từng vị trí bằng e_lfanew và chữ ký PE\x00\x00 bằng code python. Trong 8 vị trí MZ, chỉ có offset 0xFF là PE hợp lệ:

```
MZ found at: 0xff
e_lfanew: 0x108
Expected PE: 0x207
Signature: b'PE\x00\x00'
>>> VALID PE HEADER FOUND <<<
```

```
Expected PE: 0x48005c1a  
[-] PE offset outside file
```

```
=====
```

```
MZ found at: 0x6d57  
e_lfanew: 0x48077500  
Expected PE: 0x4807e257  
[-] PE offset outside file
```

```
=====
```

```
MZ found at: 0x18d45  
e_lfanew: 0x74ff85d8  
Expected PE: 0x7501131d  
[-] PE offset outside file
```

```
=====
```

```
MZ found at: 0x19767  
e_lfanew: 0xfd00348  
Expected PE: 0xfd19aaf  
[-] PE offset outside file
```

```
=====
```

```
MZ found at: 0x1ff3f  
e_lfanew: 0x2b9  
Expected PE: 0x201f8  
Signature: b'\x06@\x80\xfe'  
[-] Not a valid PE header
```

```
=====
```

```
MZ found at: 0x2a330  
e_lfanew: 0xde8d1  
Expected PE: 0x108c01  
[-] PE offset outside file
```

Hình 25: kiểm tra từng vị trí bằng e_lfanew và chữ ký PE\x00\x00

```

main.py
1  import struct
2
3  filename = "4100_A_lon.dmp"
4
5  with open(filename, "rb") as f:
6      data = f.read()
7
8  offset = 0
9
10 print(f"File size: {len(data)} bytes\n")
11
12 while True:
13     offset = data.find(b"MZ", offset)
14
15     if offset == -1:
16         break
17
18     print("=" * 50)
19     print(f"MZ found at: {hex(offset)}")
20
21     try:
22
23         e_lfanew = struct.unpack_from("<I", data, offset + 0x3C)[0]
24         pe_offset = offset + e_lfanew
25
26         print(f"e_lfanew: {hex(e_lfanew)}")
27         print(f"Expected PE: {hex(pe_offset)}")
28
29         if pe_offset + 4 <= len(data):
30             signature = data[pe_offset:pe_offset + 4]
31
32             print(f"Signature: {signature}")
33
34             if signature == b"PE\x00\x00":
35                 print(">>> VALID PE HEADER FOUND <<<")
36             else:
37                 print("[-] Not a valid PE header")
38         else:
39             print("[-] PE offset outside file")
40
41     except Exception as e:
42         print(f"[-] Error: {e}")
43
44     offset += 2

```

Hình 26: Code Kiểm tra e_lfanew và chữ ký PE\x00\x00 bằng code python

Tiếp theo extract đúng PE từ offset 0xFF:

```
1 filename = "4100_A_lon.dmp"
2
3 with open(filename, "rb") as f:
4     data = f.read()
5
6 pe_offset = 0xFF
7
8 with open("4100_extracted_PE.exe", "wb") as f:
9     f.write(data[pe_offset:])
10
11 print("Extracted PE from offset:", hex(pe_offset))
12 print("Output: 4100_extracted_PE.exe")
13 print("Size:", len(data[pe_offset:]), "bytes")
```

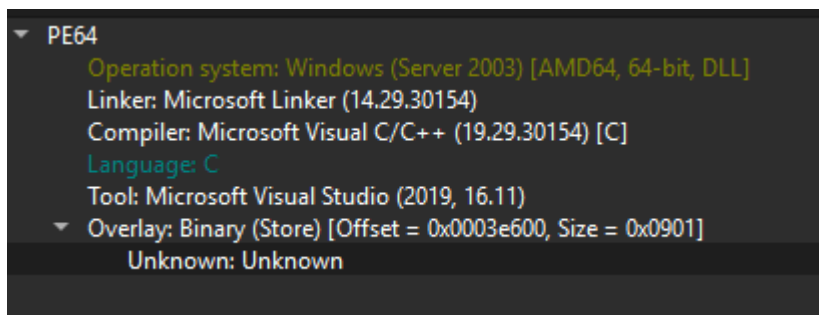
Hình 27: Extract PE từ offset 0xFF

Phân tích bằng DIE: AMD64, 64-bit, DLL → PE được extract là một DLL 64-bit, không phải .exe thông thường.

Microsoft Visual C/C++ / Visual Studio 2019 → payload được biên dịch bằng toolchain MSVC hiện đại.

Offset 0x3E600 → phần PE hợp lệ có kích thước ít nhất đến vị trí này.

Overlay 0x901 bytes → có thêm khoảng 2305 bytes dữ liệu sau phần PE/sections mà DIE không xác định được.



Hình 28: Phân tích bằng DIE tiến trình PID 4100 khi builder ra .exe

Tiếp theo E:\dmp>strings 4100_extracted_PE.dll > strings.txt
findstr /I "http https meterpreter metersrv ReflectiveLoader wininet ws2_32 urlmon LoadLibrary
GetProcAddress VirtualAlloc VirtualProtect CreateThread" strings.txt

DLL có các thành phần phục vụ giao tiếp mạng qua HTTP/HTTPS, bao gồm tạo kết nối, gửi HTTP request, nhận response và đọc/ghi dữ liệu

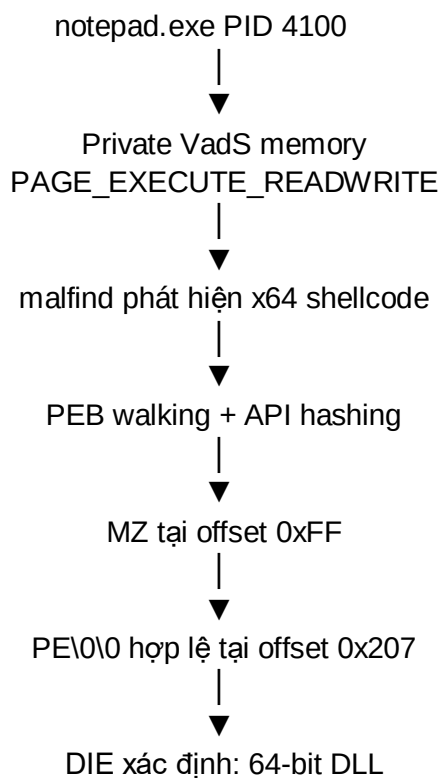
Dynamic API / DLL loading Payload có khả năng nạp DLL và resolve API động trong quá trình chạy.

Memory manipulation VirtualAllocEx VirtualProtect VirtualProtectEx → Có khả năng cấp phát và thay đổi quyền bảo vệ vùng nhớ. Đây là các API đặc biệt trong payload được phát hiện trong vùng PAGE_EXECUTE_READWRITE của Notepad.

```
https
ws2_32.dll
wininet.dll
winhttp.dll
WS2_32.dll
HttpOpenRequestW
HttpSendRequestW
HttpQueryInfoA
HttpQueryInfoW
WININET.dll
WinHttpCrackUrl
WinHttpOpen
WinHttpCloseHandle
WinHttpConnect
WinHttpReadData
WinHttpWriteData
WinHttpQueryOption
WinHttpSetOption
WinHttpOpenRequest
WinHttpSendRequest
WinHttpReceiveResponse
WinHttpQueryHeaders
WinHttpGetProxyForUrl
WinHttpGetIEProxyConfigForCurrentUser
WINHTTP.dll
GetProcAddress
LoadLibraryW
VirtualProtect
VirtualAllocEx
VirtualProtectEx
LoadLibraryA
LoadLibraryExW
```

Hình 29: strings API

Kết luận:



Sau một hồi tìm kiếm thì disassemble toàn bộ vùng 0x180006a00 → 0x180006c50

VirtualAllocEx cấp phát memory trong process khác Theo Windows x64 calling convention:

RCX = hProcess

RDX = lpAddress

R8 = dwSize

R9 = flAllocationType

Stack = flProtect

```
55 0x00000000180006ad6: mov     dword ptr [rsp + 0x20], 4
56 0x00000000180006ade: mov     r9d, 0x3000
57 0x00000000180006ae4: mov     r8d, eax
58 0x00000000180006ae7: xor     edx, edx
59 0x00000000180006ae9: mov     rcx, qword ptr [rsp + 0x70]
60 0x00000000180006aee: call    qword ptr [rip + 0x256bc]
```

The screenshot shows a disassembled assembly block. Line 60, which is highlighted, shows a call instruction: `call qword ptr [rip + 0x256bc]`. The address `0x00000000180006aee` is highlighted in blue.

Hình 30: VirtualAllocEx cấp phát memory trong process khác

WriteProcessMemory ghi payload vào target Các thanh ghi:

RCX = Target Process Handle

RDX = Remote Memory Address

R8 = Local Payload Address

R9 = Payload Size

```

63 0x0000000180006aff: jne ..... 0x180006b08
64 0x0000000180006b01: xor ..... eax, eax
65 0x0000000180006b03: jmp ..... 0x180006c18
66 0x0000000180006b08: mov ..... eax, dword ptr [rsp + 0x80]
67 0x0000000180006b0f: mov ..... qword ptr [rsp + 0x20], 0
68 0x0000000180006b18: mov ..... r9d, eax
69 0x0000000180006b1b: mov ..... r8, qword ptr [rsp + 0x78]
70 0x0000000180006b20: mov ..... rdx, qword ptr [rsp + 0x48]
71 0x0000000180006b25: mov ..... rcx, qword ptr [rsp + 0x70]
72 0x0000000180006b2a: call ..... qword ptr [rip + 0x256b8]

```

Hình 31: WriteProcessMemory ghi payload vào target Các thanh ghi

VirtualProtectEx chuyển memory thành executable Tương đương:

```

VirtualProtectEx(
    hProcess,
    remote_memory,
    payload_size,
    0x20,
    &oldProtect
);

```

```

74 0x0000000180006b32: jne ..... 0x180006b54
75 0x0000000180006b34: mov ..... r9d, 0x8000
76 0x0000000180006b3a: xor ..... r8d, r8d
77 0x0000000180006b3d: mov ..... rdx, qword ptr [rsp + 0x48]
78 0x0000000180006b42: mov ..... rcx, qword ptr [rsp + 0x70]
79 0x0000000180006b47: call ..... qword ptr [rip + 0x2566b]
80 0x0000000180006b4d: xor ..... eax, eax
81 0x0000000180006b4f: jmp ..... 0x180006c18
82 0x0000000180006b54: mov ..... eax, dword ptr [rsp + 0x80]
83 0x0000000180006b5b: lea ..... rcx, [rsp + 0x44]
84 0x0000000180006b60: mov ..... qword ptr [rsp + 0x20], rcx
85 0x0000000180006b65: mov ..... r9d, 0x20
86 0x0000000180006b6b: mov ..... r8d, eax
87 0x0000000180006b6e: mov ..... rdx, qword ptr [rsp + 0x48]
88 0x0000000180006b73: mov ..... rcx, qword ptr [rsp + 0x70]
89 0x0000000180006b78: call ..... qword ptr [rip + 0x25642]

```

Hình 32: VirtualProtectEx chuyển memory thành executable

CreateRemoteThread thực thi payload Đoạn này rất quan trọng. remote_memory + offset Tạo địa chỉ entry point: RemoteThreadStart = RemoteMemoryAddress + Offset


```

0x00000000180006b9f: mov     eax, dword ptr [rsp + 0x40]
0x00000000180006ba3: mov     rcx, qword ptr [rsp + 0x48]
0x00000000180006ba8: add     rcx, rax
0x00000000180006bab: mov     rax, rcx
0x00000000180006bae: mov     qword ptr [rsp + 0x58], rax

```

Hình 33: CreateRemoteThread thực thi payload

Điều quan trọng: offset trước CreateRemoteThread [rsp + 0x40] được lấy từ:

0x180006abd: call 0x1800066d8

0x180006ac1: mov dword ptr [rsp + 0x40], eax Nghĩa là hàm 0x1800066d8 trả về một offset. Do đó payload được thực thi không nhất thiết bắt đầu ở byte đầu tiên:

```

0x00000000180006b9f: mov     eax, dword ptr [rsp + 0x40]
0x00000000180006ba3: mov     rcx, qword ptr [rsp + 0x48]
0x00000000180006ba8: add     rcx, rax

```

Hình 34: Xác định Offset Entry Point của Payload trước khi gọi CreateRemoteThread

1.3. Dump NetWork

Dùng Vol3 plugin netscan. nhận thấy tại thời điểm dump RAM kết nối này vẫn được chạy đây là một ip lạ với port

```

0xa408f2559010 TCPv4 172.16.179.146 49879 172.16.179.139 6667 ESTABLISHED - - N/A

```

Hình 35: NetWork Memory Dump

1.4. Kết luận sơ bộ chuỗi tấn công.



1.5. Registry Hive trong RAM

Danh sách chứa đầy đủ các tệp cấu hình cốt lõi nằm trong thư mục System32\Config

Các hive này xuất hiện trong RAM kể cả ở trạng thái disabled chứng minh chúng đã từng được hệ thống hoặc một tiến trình nào đó đọc nạp vào bộ nhớ.

```
E:\Tools\volatility3-develop>python vol.py -f E:\DESKTOP-BMNA5D9-20260811-
Volatility 3 Framework 2.28.1
Progress: 100.00          PDB scanning finished
Offset  FileFullPath      File output
0xc609a260a000          Disabled
0xc609a260e000  \REGISTRY\MACHINE\SYSTEM      Disabled
0xc609a26a3000  \REGISTRY\MACHINE\HARDWARE    Disabled
0xc609a5226000  \Device\HarddiskVolume1\EFI\Microsoft\Boot\BCD Disabled
0xc609a50e6000  \SystemRoot\System32\Config\SOFTWARE Disabled
0xc609a5d40000  \SystemRoot\System32\Config\DEFAULT Disabled
0xc609a5e8a000  \SystemRoot\System32\Config\SECURITY Disabled
```

Hình 35: Các hive này xuất hiện trong RAM

VI. PHÂN TÍCH DISK

1.Sysmon

2026-08-10 09:30:07.543 UTC Notepad khởi tạo kết nối TCP đến địa chỉ IP nội bộ 172.16.179.139 qua cổng 6667 -> đúng với phân trước chắc chắn notepad đã tiêm mã độc

+ System	
- EventData	
RuleName	Usermode
UtcTime	2026-08-10 09:30:07.543
ProcessGuid	{0fdd9941-0631-6a7b-2202-000000000400}
ProcessId	7264
Image	C:\Users\sam\Desktop\7z2301-x64\7zG.exe
User	DESKTOP-BMNA5D9\sam
Protocol	tcp
Initiated	true
SourceIsIpv6	false
SourceIp	172.16.179.146
SourceHostname	DESKTOP-BMNA5D9.localdomain
SourcePort	49792
SourcePortName	-
DestinationIsIpv6	false
DestinationIp	172.16.179.139
DestinationHostname	-
DestinationPort	6667
DestinationPortName	-

Hình 36: Notepad khởi tạo kết nối TCP

Thời gian xảy ra (UtcTime): 2026-08-11 13:46:58.180 UTC. tại CurrentDirectory: C:\Users\sam\Desktop\7z2301-x64\ notepad.exe tạo lệnh cmd.exe

RuleName	-
UtcTime	2026-08-11 13:46:58.180
ProcessGuid	{0fdd9941-27d2-6a7b-2d02-000000000500}
ProcessId	2936
Image	C:\Windows\System32\cmd.exe
FileVersion	10.0.17763.1 (WinBuild.160101.0800)
Description	Windows Command Processor
Product	Microsoft® Windows® Operating System
Company	Microsoft Corporation
OriginalFileName	Cmd.Exe
CommandLine	C:\Windows\system32\cmd.exe
CurrentDirectory	C:\Users\sam\Desktop\7z2301-x64\
User	DESKTOP-BMNA5D9\sam
LogonGuid	{0fdd9941-0eef-6a7b-9ebb-040000000000}
LogonId	0x4bb9e
TerminalSessionId	1
IntegrityLevel	Medium
Hashes	MD5=0D088F5BCFA8F086FBA163647CD80CAB,SHA256=9023F8AAEDA4A1DA45AC477
ParentProcessGuid	{0fdd9941-1bcd-6a7b-0a02-000000000500}
ParentProcessId	2160
ParentImage	C:\Windows\System32\notepad.exe
ParentCommandLine	C:\Windows\System32\notepad.exe
ParentUser	DESKTOP-BMNA5D9\sam

Hình 37: Notepad.exe tạo lệnh cmd.exe

Thời gian xảy ra (UtcTime): 2026-08-11 13:00:16.454 UTC. notepad.exe đã tạo hoặc ghi tệp mới có tên HiveNightmare.exe

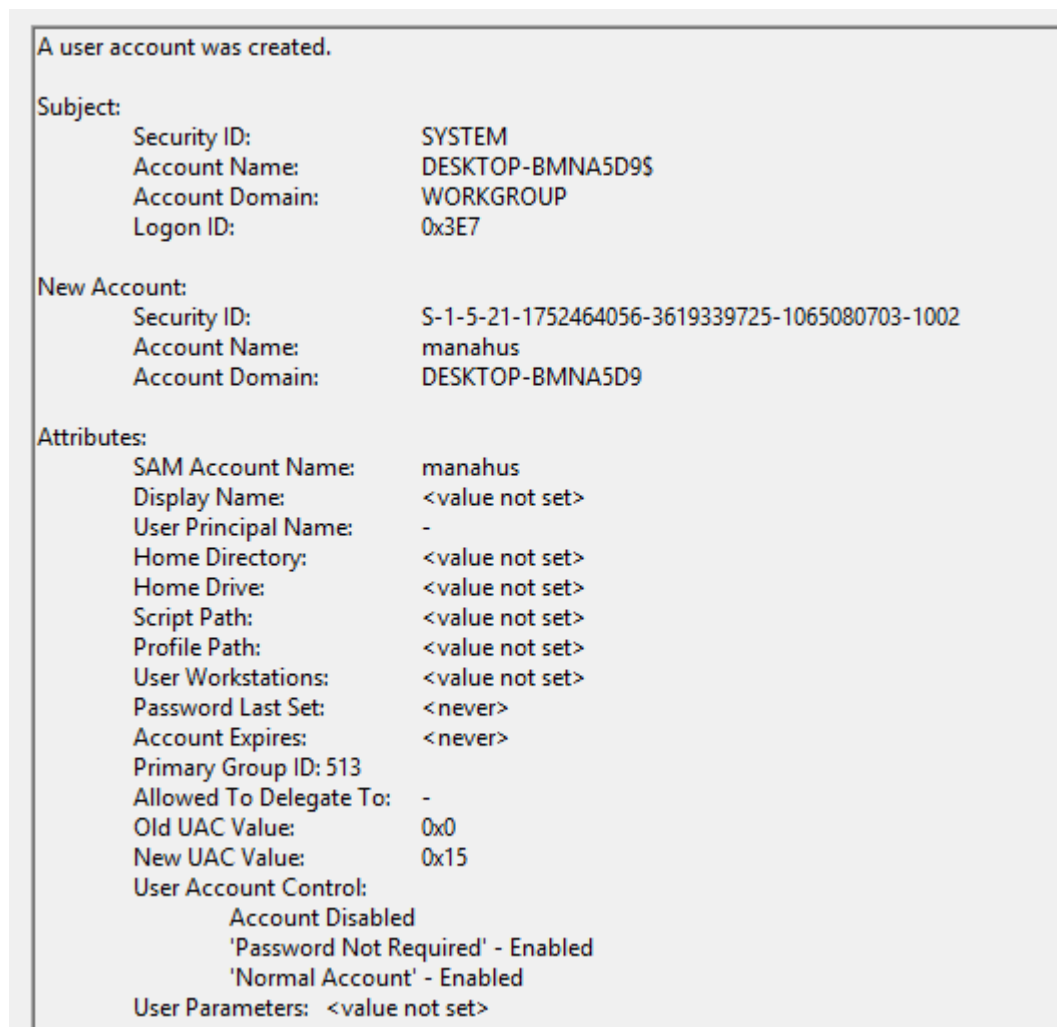
+ System	
- EventData	
RuleName	EXE
UtcTime	2026-08-11 13:00:16.454
ProcessGuid	{0fdd9941-1bcd-6a7b-0a02-000000000500}
ProcessId	2160
Image	C:\Windows\System32\notepad.exe
TargetFilename	C:\Users\sam\Desktop\7z2301-x64\HiveNightmare.exe
CreationUtcTime	2026-08-11 13:00:16.454
User	DESKTOP-BMNA5D9\sam

Hình 38: notepad.exe đã tạo hoặc ghi tệp mới có tên HiveNightmare.exe

Thời gian xảy ra (UtcTime): 2026-08-11 14:25:23.596 UTC. Câu lệnh net user để khởi tạo tài khoản mới có tên manahus kèm mật khẩu: P@darsaeffv!

+ System	
- EventData	
RuleName	-
UtcTime	2026-08-11 14:25:23.596
ProcessGuid	{0fdd9941-30d3-6a7b-5302-000000000500}
ProcessId	2660
Image	C:\Windows\SysWOW64\net1.exe
FileVersion	10.0.17763.1 (WinBuild.160101.0800)
Description	Net Command
Product	Microsoft® Windows® Operating System
Company	Microsoft Corporation
OriginalFileName	net1.exe
CommandLine	C:\Windows\system32\net1 user manahus P@darsaeffv! /add
CurrentDirectory	C:\Windows\system32\
User	NT AUTHORITY\SYSTEM
LogonGuid	{0fdd9941-0edb-6a7b-e703-000000000000}
LogonId	0x3e7
TerminalSessionId	0
IntegrityLevel	System
Hashes	MD5=E28124DF01CA79FD93F3B7C48DECDAC0,SHA256=383ECC5DBCDD98
ParentProcessGuid	{0fdd9941-30d3-6a7b-5202-000000000500}
ParentProcessId	3252
ParentImage	C:\Windows\SysWOW64\net.exe
ParentCommandLine	net user manahus P@darsaeffv! /add
ParentUser	NT AUTHORITY\SYSTEM

Hình 39: net user để khởi tạo tài khoản mới có tên manahus



Hình 40: net user để khởi tạo tài khoản mới có tên manahus Log security

Loại đăng nhập Logon Type: 3, cho thấy một kết nối mạng từ xa đến hệ thống. Login vào tài khoản quản trị: backup_admin từ địa chỉ IP 172.16.179.139 qua port 37692 đây đã xác định là ip tấn công.

```

+ System
- EventData
  SubjectUserSid S-1-0-0
  SubjectUserName -
  SubjectDomainName -
  SubjectLogonId 0x0
  TargetUserSid S-1-5-21-1752464056-3619339725-1065080703-1001
  TargetUserName backup_admin
  TargetDomainName DESKTOP-BMNA5D9
  TargetLogonId 0x2ca6d9
  LogonType 3
  LogonProcessName NtLmSsp
  AuthenticationPackageName NTLM
  WorkstationName -
  LogonGuid {00000000-0000-0000-0000-000000000000}
  TransmittedServices -
  LmPackageName NTLM V2
  KeyLength 128
  ProcessId 0x0
  ProcessName -
  IpAddress 172.16.179.139
  IpPort 37692
  ImpersonationLevel %%1833
  RestrictedAdminMode -
  TargetOutboundUserName -
  TargetOutboundDomainName -
  VirtualAccount 0x0 1 0 1 2

```

Hình 41: Loại đăng nhập Logon Type: 3

cmd.exe, tại thư mục C:\Users\sam\Desktop\7z2301-x64\, chạy lệnh vssadmin list shadows, khiến cmd.exe khởi tạo chương trình C:\Windows\System32\vssadmin.exe Liệt kê tất cả Volume Shadow Copy đang tồn tại trên máy.

```

RuleName -
UtcTime 2026-08-11 12:56:04.646
ProcessGuid {0 added9941-1be4-6a7b-1202-000000000500}
ProcessId 4872
Image C:\Windows\System32\vssadmin.exe
FileVersion 10.0.17763.1 (WinBuild.160101.0800)
Description Command Line Interface for Microsoft® Volume Shadow Copy Service
Product Microsoft® Windows® Operating System
Company Microsoft Corporation
OriginalFileName VSSADMIN.EXE
CommandLine vssadmin list shadows
CurrentDirectory C:\Users\sam\Desktop\7z2301-x64\
User DESKTOP-BMNA5D9\sam
LogonGuid {0 added9941-0eef-6a7b-9ebb-040000000000}
LogonId 0x4bb9e
TerminalSessionId 1
IntegrityLevel Medium
Hashes MD5=614B5C4238977130AA2270C8AD58CE6C,SHA256=D7577FB88CCA3169C7931DC0D8EC9A444227DC14F6C71D6D39D86A0C5CAD1976,IMPHASH=
ParentProcessGuid {0 added9941-1bd9-6a7b-1002-000000000500}
ParentProcessId 6976
ParentImage C:\Windows\System32\cmd.exe
ParentCommandLine C:\Windows\system32\cmd.exe
ParentUser DESKTOP-BMNA5D9\sam

```

Hình 42: khởi tạo chương trình C:\Windows\System32\vssadmin.exe

2. Phân tích Registry Hive

2.1. Phân tích Hive SAM

Tài khoản manahus ho hacker tạo có mốc thời gian là 2026-08-11 14:25:23, khớp hoàn toàn với thời gian tạo trước đó trên lệnh có RegUnknown (0x3EA, 1002 decimal)

Names				
Administrator	1	7	2026-08-11 14:25:23	
backup_admin	1	0	2026-08-09 21:00:28	
DefaultAccount	1	0	2026-08-11 11:18:25	
Guest	1	0	2026-08-09 21:00:28	
manahus	1	0	2026-08-09 21:00:28	
sam	1	0	2026-08-11 14:25:23	
WDAGUtilityAccount	1	0	2026-08-09 20:58:26	
	1	0	2026-08-09 21:00:28	

Hình 43: Tài khoản manahus trong SAM

Trong service\cVSq Service tạm thời phát hiện FXKliBTA.exe trong trường hợp này mục đích chính là làm service executable tạm thời cho

	Value Name	Value Type	Data
	Type	RegDword	16
	Start	RegDword	3
	ErrorControl	RegDword	0
	ImagePath	RegExpandSz	%systemroot%\FXKliBTA.exe
	DisplayName	RegSz	cVSq
	ObjectName	RegSz	LocalSystem

Hình 44: Service tạm thời phát hiện FXKliBTA.exe trong SECURITY

VII. TIMELINE ATTACK

Thời Gian	Hoạt động
2026-08-10 09:30:07.543 UTC	Lần đầu tiên User kết nối đến hacker
2026-08-11 12:53:33 UTC	Ứng dụng 7z được chạy khởi chạy
2026-08-11 12:56:04.646 UTC	Liệt kê tất cả Volume Shadow Copy
2026-08-11 13:00:16 UTC	Malware trong 7-Zip tạo ghi HiveNightmare.exe
2026-08-11 13:03:45 UTC	Các file Registry Hive SAM, SYSTEM, SECURITY được tạo thư mục 7-Zip
2026-08-11 13:46:58 UTC	notepad.exe tạo tiến trình cmd.exe từ thư mục C:\Users\sam\Desktop\7z2301-x64\.
2026-08-11 14:24:21 UTC	Có Logon Type 3 từ IP 172.16.179.139 sử dụng tài khoản backup_admin.
2026-08-11 14:25:23 UTC	Lệnh net user được sử dụng để tạo tài khoản manahus.

VIII. MITRE ATT&CK

ATT&CK Phase	Technique ID	Technique	Bằng chứng
Initial Access	T1566	Phishing	Người dùng bị lừa tải file cài đặt giả mạo có chứa thành phần độc hại.
	T1574.002	Hijack Execution Flow: DLL Side-Loading	7zFM.exe tải 7z.dll giả mạo trong thư mục 7z2301-x64; DLL độc hại forward các hàm sang g_7z.dll để duy trì hoạt động bình thường Ảnh
Execution	T1059.003	Windows Command Shell	notepad.exe tạo tiến trình cmd.exe Ảnh
	T1106	Native API	DLL thực hiện chuỗi API VirtualAlloc → memmove → CreateThread để nạp và thực thi shellcode trong bộ nhớ. Ảnh
Privilege Escalation	T1068	Exploitation for Privilege Escalation	HiveNightmare.exe xuất hiện cùng các Registry Hive SAM, SYSTEM, SECURITY; báo cáo xác định hoạt động liên quan đến CVE-2021-36934 Ảnh
Credential Access	T1003	OS Credential Dumping	Các file SAM và SYSTEM được truy cập; PID 2160 vẫn giữ handle tới SAM-2026-08-11 và SYSTEM-2026-08-11 Ảnh
Credential Access	T1003.002	Security Account Manager	File SAM được thu thập từ hệ thống, phục vụ việc truy xuất thông tin xác thực/NTLM hash.

Account Manipulation	T1098	Account Manipulation	Lệnh net user được sử dụng tạo tài khoản manahus. <u>Ảnh</u>
Persistence	T1136.001	Create Account: Local Account	Registry SAM cho thấy tài khoản manahus được tạo vào 2026-08-11 14:25:23 <u>Ảnh</u>
Execution / Lateral Movement	T1569.002	System Services: Service Execution	upload FXKliBTA.exe, tạo service tạm thời cVSq và khởi động service để thực thi với quyền SYSTEM. <u>Ảnh</u>
Defense Evasion / Execution	T1055.002	Process Injection: Portable Executable Injection	Trong vùng nhớ notepad.exe PID 4100 phát hiện shellcode và PE DLL hợp lệ được nhúng trong memory.
Defense Evasion / Execution	T1055	Process Injection	Phân tích disassembly cho thấy chuỗi VirtualAllocEx → WriteProcessMemory → VirtualProtectEx → CreateRemoteThread để thực thi payload trong notepad.exe.
Command and Control	T1071.001	Application Layer Protocol: Web Protocols	Payload có các API/chức năng liên quan HTTP/HTTPS; báo cáo nhận định payload thực hiện reverse HTTP. <u>Ảnh</u>
Command and Control	T1571	Non-Standard Port	notepad.exe thiết lập kết nối tới 172.16.179.139:6667; cổng 6667 được sử dụng cho kết nối C2. <u>Ảnh</u>
Discovery	T1083	File and Directory Discovery	Liệt kê các Volume Shadow Copy để xác định các bản sao có

			thể chứa Registry Hive như SAM, SYSTEM, SECURITY. <u>Ảnh</u>
--	--	--	--

IX. KHẮC PHỤC CẢI THIẾN

1. Khắc phục nguy cơ người dùng tải và thực thi file giả mạo

Chuỗi tấn công bắt đầu từ việc người dùng tải và thực thi một file giả mạo có giao diện và chức năng tương tự phần mềm 7-Zip hợp lệ. File độc hại được đóng gói để tạo cảm giác giống bộ cài đặt hợp pháp.

Cần áp dụng các biện pháp:

- Chỉ cho phép người dùng tải phần mềm từ website chính thức hoặc kho phần mềm được tổ chức phê duyệt.
- Kiểm tra digital signature và hash của file trước khi triển khai.
- Sử dụng Application Control như AppLocker hoặc Windows Defender Application Control để hạn chế việc chạy file .exe từ các thư mục không tin cậy.
- Huấn luyện người dùng nhận biết phần mềm giả mạo và các website phát tán file độc hại.
- Sử dụng cơ chế lọc web và chặn các domain phát tán phần mềm không được phê duyệt.

2. Ngăn chặn DLL Search Order Hijacking

Trong tấn công, attacker thay thế 7z.dll bằng DLL giả mạo. DLL này vẫn chuyển tiếp các hàm cần thiết đến DLL hợp lệ để 7-Zip tiếp tục hoạt động bình thường, đồng thời thực thi payload trong bộ nhớ.

Biện pháp khắc phục:

- Không chạy ứng dụng từ thư mục có thể bị người dùng ghi hoặc chỉnh sửa tùy ý.
- Đặt các file thực thi và DLL trong thư mục được bảo vệ bằng quyền NTFS phù hợp.
- Kiểm tra tính toàn vẹn của các DLL quan trọng bằng hash hoặc digital signature.
- Sử dụng đường dẫn tuyệt đối khi ứng dụng nạp DLL thay vì phụ thuộc vào DLL Search Order.
- Giám sát các DLL được nạp bởi những ứng dụng phổ biến như 7zFM.exe.
- Phát hiện trường hợp DLL cùng tên với DLL hợp lệ nhưng có hash, chữ ký hoặc đường dẫn bất thường.

3. Vá CVE-2021-36934 và bảo vệ Registry Hive

Trong chuỗi tấn công, attacker lợi dụng quyền truy cập không đúng đối với các bản sao Registry Hive thông qua Volume Shadow Copy

Biện pháp quan trọng nhất là:

- Cập nhật Windows bằng các bản vá bảo mật phù hợp.
- Kiểm tra các quyền truy cập đối với Registry Hive.
- Kiểm tra quyền truy cập của nhóm BUILTIN\Users đối với các file nhạy cảm.
- Kiểm tra và hạn chế việc truy cập Volume Shadow Copy không cần thiết.
- Giám sát các tiến trình thực hiện hành vi liệt kê hoặc truy cập Shadow Copy.
- Cảnh báo khi tiến trình không đáng tin cậy cố đọc hoặc sao chép SAM, SYSTEM, hoặc SECURITY.

4. Phát hiện và ngăn chặn Credential Dumping

Sau khi lấy được Registry Hive, attacker sử dụng chúng để thu thập NTLM hash của tài khoản backup_admin.

Cần giám sát:

- Truy cập bất thường tới SAM, SYSTEM, SECURITY.
- Việc tạo các bản sao Hive trong thư mục người dùng hoặc thư mục tạm.
- Công cụ hoặc tiến trình thực hiện dump credential.
- Việc xuất hiện hash của tài khoản privileged trong các file hoặc tiến trình bất thường.

5. Hạn chế Pass-the-Hash

Attacker sử dụng NTLM hash của backup_admin để xác thực từ xa và thực thi:

Các biện pháp:

- Hạn chế hoặc vô hiệu hóa NTLM ở những môi trường có thể sử dụng Kerberos.
- Không sử dụng cùng mật khẩu local administrator trên nhiều máy.
- Áp dụng Windows LAPS để quản lý mật khẩu local administrator riêng biệt cho từng endpoint.
- Hạn chế tài khoản quản trị đăng nhập từ xa.
- Phân tách tài khoản người dùng thông thường và tài khoản quản trị.
- Giám sát Logon Type 3 từ các địa chỉ IP bất thường.
- Theo dõi các lần xác thực của tài khoản privileged từ workstation không thông thường.

6. Hạn chế SMB và Administrative Share

Các biện pháp:

- Hạn chế SMB giữa các endpoint nếu không cần thiết.

- Chỉ cho phép các máy quản trị được xác định truy cập administrative share.
- Phân đoạn mạng để workstation không thể tự do kết nối SMB tới các máy khác.
- Giám sát việc ghi file vào ADMIN\$.
- Cảnh báo khi executable được upload thông qua SMB rồi ngay sau đó được thực thi.

7. Phát hiện Process Injection

Nên giám sát:

- Một process mở handle tới process khác với quyền ghi bộ nhớ.
- WriteProcessMemory vào tiến trình khác.
- Việc tạo remote thread.
- Vùng nhớ private có quyền RWX.
- Process hợp lệ như notepad.exe nhưng thực hiện kết nối mạng bất thường.

8. Giám sát Command and Control

Nên phát hiện:

- Các ứng dụng thông thường không có chức năng mạng nhưng tạo outbound connection.
- Kết nối đến IP không thuộc danh sách hệ thống được phép.
- Kết nối qua cổng không phổ biến đối với ứng dụng đó.
- Kết nối mạng xuất hiện sau khi process có dấu hiệu injection.

X. CÁC CÔNG CỤ ĐÃ DÙNG.

Sysmon: Xem log cảnh báo.

IDA: phân tích hành vi mã độc.

Registry explorer: xem các file Registry Hive.

Python, VScode: Phân tích hành vi shellcode.

TimeLine explorer: Dùng để xem tìm kiếm gọn hơn.

DIE: Xem cấu trúc file.

VirusTotal: Phân tích đánh giá độ nguy hiểm mã độc.

FTK Image: Đọc file Disk.

Voalyty3: Phân tích file Dump Memory.

PE Bear: phân tích .Selection

